

SOC Security Onion & Kibana 脅威ハンティング

Security Onion (SO) は、Zeek、Suricata、Wazuh(Sysmon)のログを **Elastic Common Schema (ECS)** に正規化しています。本チートシートは、Kibanaの「Discoverタブ」で打ち込む **KQL (Kibana Query Language)** と、ダッシュボードでの可視化手法 (GUI操作) をサイバークルチェーンの各フェーズにマッピングした完全網羅版です。

1. 偵察 (Reconnaissance)

ポートスキャンやWeb脆弱性スキャン、ADのLDAP探索を検知します。

1-1. Webサーバーへの404スキャン検知

Zeek HTTP
KQLクエリ

```
# ZeekのHTTPログで404エラーをフィルタ
event.dataset: "zeek.http" AND http.response.status_code: 404
```

【Kibana可視化 (Lens / Data Table)】

Rows: source.ip (Top values)

Metrics: Count および Unique count of url.path

※特定の送信元から多種多様なURIへ404が発生していればスキャンと判定。

1-2. SMB (445) / LDAP (389, 636) スキャンと列挙

Zeek Conn
Sysmon

```
# ネットワーク側 (Zeek) の特定ポートへのアクセス、またはホスト側 (AD) のLDAPクエリ
destination.port: (445 OR 389 OR 636)
OR (winlog.event_id: 1644 AND winlog.channel: "Directory Service")
```

2. 武器化 (Weaponization) & 3. 配送 (Delivery)

既知の悪性ハッシュ、マクロ付きファイル、不審なドメインからのダウンロード、およびメールでの着弾を追跡します。

2-1. 悪性ハッシュ (SHA256) や拡張子の検知

Zeek Files
Sysmon

```
# ネットワーク (Zeek) とホスト (Sysmon) を横断して、特定のハッシュや拡張子を検索
file.hash.sha256: "悪性ハッシュ文字列"
OR (file.extension: ("exe" OR "dll" OR "docm" OR "xlsm") AND
event.dataset: "zeek.files")
```

【Kibana可視化】 Discoverタブで file.name, source.ip, destination.ip をカラムに追加して俯瞰。

3-1. 不審なメールドロップと認証失敗 (SPF/DKIM)

Zeek SMTP

```
# スプーフィングの疑いがあるメールや、配送エラー
event.dataset: "zeek.smtp" AND (suricata.eve.email.status: "fail"
OR zeek.smtp.success: false)
```

4. エクスプロイト (Exploitation)

4-1. IDS/IPS (Suricata) による攻撃ブロックアラート

Suricata

```
# Suricataが検知（またはブロック）したWeb攻撃や脆弱性エクスプロイト
event.module: "suricata" AND event.category: ("intrusion_detection"
OR "web") AND suricata.eve.alert.action: ("blocked" OR "dropped")
```

【Kibana可視化】 Data Tableで Rows: suricata.eve.alert.signature (シグネチャ名) 別にカウント。

4-2. Webシェル実行の検知 (MUST-HAVE)

Sysmon

```
# Webサーバープロセス(w3wp, nginx等)がシェル(cmd, powershell等)を起動する
異常挙動
winlog.event_id: 1 AND process.parent.name: ("w3wp.exe" OR
"nginx.exe" OR "httpd.exe" OR "tomcat.exe") AND process.name:
("cmd.exe" OR "powershell.exe" OR "sh" OR "bash")
```

5. インストール (Installation & Persistence)

5-1. ステルス永続化 (レジストリ、WMI、サービス)

Sysmon / WinEvent

```
# Sysmon(レジストリ変更/WMIバインド) または Windows標準(サービス/タスク作成)
(winlog.event_id: (12 OR 13 OR 14) AND registry.path: *Run*)
OR winlog.event_id: (19 OR 20 OR 21)
OR winlog.event_id: (7045 OR 4698)
```

6. 遠隔操作 (Command and Control - C2)

6-1. ビーコニング (定時性通信) の特定

Zeek HTTP/Conn

```
# まずは不審な長期間のセッションや、1日の通信回数が多い内部IPをフィルタ
event.dataset: "zeek.conn" AND network.direction: "outbound" AND
(network.packets > 1000 OR event.duration > 3600000000000)
```

【Kibana可視化 (TSVB - Time Series Visual Builder)】

ビーコニング検知はグラフ化が必須です。TSVBを使用し、X軸をTime、Y軸をCountにし、Group byを destination.ip に設定します。波形が「一定間隔でトゲ（スパイク）を作る」場合、低JitterのC2ビーコン通信です。

6-2. DNSエントロピー (DNSトンネリング)

Zeek DNS

```
# Lucene正規表現を利用して、文字数が異様に長い(40文字以上)クエリを検索
event.dataset: "zeek.dns" AND dns.question.name: /.{40,}/
```

7. 目的の実行 (Actions on Objectives)

7-1. ボリュームシャドウコピー (VSS) の削除 (ランサムウェア直前・Critical)

Sysmon	<pre># ランサムウェアによる暗号化直前のVSS削除コマンドを検知 winlog.event_id: 1 AND process.command_line: (*vssadmin*delete* OR *wmic*shadowcopy*delete* OR *bcdedit*recoveryenabled\ No*)</pre>
--------	---

7-2. 大量データの持ち出し (Exfiltration) とログ消去

Zeek Conn WinEvent	<pre># ネットワーク外への大容量送信(例: 50MB=50,000,000Bytes以上)、または監査ログ の消去 (event.dataset: "zeek.conn" AND network.direction: "outbound" AND source.bytes >= 500000000) OR winlog.event_id: (1102 OR 104)</pre>
-----------------------	--

★ Security Onion 独自機能の活用 (Pro Tips)

Security Onionのダッシュボード(SOC UI)には、Kibanaをラップした独自の強力な機能があります。

Hunt (ハント機能)	SplunkのSPLに近い感覚で、groupby メトリクスを使用してデータを素早くグループ化・集計できるSecurity Onion専用の画面です。KibanaのDashboardを作るまでもない一時的な調査に最適です。
PCAP (パケット取得)	ログの詳細（展開されたドキュメント）から、_idをクリックして PCAP タブに遷移すると、ArkimeやWiresharkを開かなくとも、Webブラウザ上で直接そのセッションのフルパケットの中身（ASCII/HEX）を確認し、ダウンロードできます。